

ReFineID — déclaration d'un moyen de cryptologie

Déclaration de fourniture et de transfert depuis un État membre de l'Union européenne d'un moyen de cryptologie, au titre de l'article 30 de la loi n° 2004-575 du 21 juin 2004 pour la confiance dans l'économie numérique et du chapitre II du décret n° 2007-663 du 2 mai 2007.

ReFineID est un intergiciel qui rend la carte nationale d'identité finlandaise utilisable comme identité numérique sur les plateformes Apple. Il établit avec la carte un canal chiffré et assure à ce titre une fonction de confidentialité, outre l'authentification, l'intégrité et la signature : sa fourniture relève du régime de déclaration.

Le déclarant demande la délivrance de l'attestation de déclaration.

A. Déclarant et/ou demandeur

Le déclarant est un particulier. ReFineID est un nom commercial qu'il emploie en son nom propre.

Champ	Valeur
Nom et prénoms	Koistinen, Petri
Nationalité	finlandaise
Adresse	Niittajankatu 8a A 21, 00810 Helsinki, Finlande
Numéro de téléphone	+358 44 956 4098
Adresse de courrier électronique	petri.koistinen@iki.fi

Contact technique : le déclarant, aux mêmes coordonnées. Il est également le fabricant du moyen.

B. Moyen de cryptologie auquel s'appliquent la déclaration et/ou la demande d'autorisation

B.1. Informations générales sur le moyen

Champ	Valeur
Dénomination du moyen	ReFineID
Désignation générique	Intergiciel pour carte nationale d'identité
Marque de distribution	ReFineID
Référence commerciale	ReFineID pour plateformes Apple
Version	26.11
Date de mise sur le marché	1er novembre 2026
Plateformes	iOS 26, iPadOS 26, macOS 26

B.2. Description fonctionnelle du moyen

B.2.1. Classez le moyen dans la ou les catégorie(s) correspondante(s) Logiciel.

B.2.2. Description générale du moyen

Le moyen lit la carte via l'antenne NFC du téléphone ou un lecteur de carte à contact, publie le certificat d'authentification et la clé publique de la carte dans le trousseau du système par CryptoTokenKit, et transmet les demandes de signature à la carte. Safari et les autres applications du système s'authentifient ensuite avec la carte comme avec tout autre certificat client.

La présente déclaration porte sur la seule application pour plateformes Apple, distribuée par l'App Store. Un intergiciel ReFineID pour postes de travail, distribué séparément et dont les fonctions cryptographiques diffèrent, n'entre pas dans son champ.

B.2.3. Indiquez à quelle catégorie se rapporte la fonction principale du moyen Sécurité de l'information (bibliothèque et intergiciel cryptographiques).

B.3. Description technique des services de cryptologie fournis

B.3.1. Description des fonctionnalités cryptographiques du moyen

Deux fonctions, et aucune autre :

1. **Établissement d'un canal sécurisé avec la carte.** La carte refuse toute lecture de son application PKCS#15 sur l'interface sans contact tant que PACE n'a pas été exécuté. PACE dérive des clés de session à partir du numéro d'accès imprimé sur la carte ; tous les échanges ultérieurs sont chiffrés et authentifiés au moyen de ces clés.
2. **Signatures d'authentification client.** La clé privée reste dans la carte, qui réalise la signature. Le moyen met en forme l'entrée, la transmet à la carte, et vérifie le résultat avec la clé publique de la carte avant de le restituer au système d'exploitation.

Le chiffrement est confiné à ce canal et à la seule interface sans contact. Il n'est pas offert au porteur : il est imposé par la politique d'accès de la carte. Sur l'interface à contact, le moyen ne chiffre rien. La clé publiée au système d'exploitation est réservée à la signature : le moyen n'offre à ses appelants ni déchiffrement ni accord de clés.

Le moyen ne chiffre pas les données de l'utilisateur au repos, ne chiffre ni fichiers ni supports de stockage, n'offre ni messagerie ni téléphonie chiffrées, ne met en œuvre aucun réseau privé virtuel (VPN) ni tunnel de transport, et n'établit par lui-même aucune communication réseau.

B.3.2. Indiquez à quelle(s) catégorie(s) se rapporte(nt) la ou les fonctions cryptographiques du moyen

Authentification, intégrité, confidentialité et signature.

B.3.3. Indiquez le(s) protocole(s) sécurisé(s) utilisés par le moyen

Ni IPsec, ni SSH, ni protocoles de VoIP, ni SSL/TLS. TLS est assuré par le système d'exploitation ; le moyen ne met en œuvre aucune pile TLS et se borne à fournir la signature calculée par la carte.

Autres protocoles : PACE selon ICAO Doc 9303 partie 11 et BSI TR-03110-3 ; messagerie sécurisée selon ISO/IEC 7816-4.

B.3.4. Précisez les algorithmes cryptographiques utilisés et leurs longueurs maximales de clés

Les opérations sur la courbe brainpoolP384r1 et le CMAC sont écrits dans le moyen ; l'AES, le SHA-2 et la vérification des signatures ECDSA et RSA sont appelés dans les bibliothèques du système d'exploitation. Tous les algorithmes sont publiés par des organismes de normalisation internationaux ; aucun n'est propriétaire.

Algorithme	Mode	Taille de clé	Fonction
ECDH sur brainpoolP384r1	PACE-GM (mappage générique)	384 bits	Accord de clés PACE
AES	CBC	256 bits	Confidentialité de chaque APDU après PACE
AES	CMAC	256 bits	Intégrité de chaque APDU après PACE
SHA-256	s.o.	s.o.	Dérivation des clés de session PACE
SHA-224, SHA-256, SHA-384, SHA-512	s.o.	s.o.	Condensats des signatures d'authentification
ECDSA sur NIST P-384	s.o.	384 bits	Signature d'authentification client
RSA	PKCS#1 v1.5	3072 bits	Signature d'authentification client
RSA	PSS	3072 bits	Signature d'authentification client

La fonction de condensation des signatures ECDSA est choisie par le service appelant ; les cartes à clé RSA n'emploient que SHA-256.

Normes correspondantes : ECDH, RFC 5639 et BSI TR-03111 ; AES, FIPS 197 avec NIST SP 800-38A (CBC) et NIST SP 800-38B avec RFC 4493 (CMAC) ; SHA-2, FIPS 180-4 ; ECDSA, FIPS 186-5 et ANSI X9.62 ; RSA, RFC 8017.

Gestion des clés

- Les clés privées sont générées dans la carte par l'autorité émettrice et n'en sortent jamais. Le moyen ne peut pas les lire et ne les détient jamais.
- Les clés de session PACE sont éphémères : dérivées par session, gardées en mémoire seulement, libérées à la fin de la session et jamais écrites sur un support persistant.
- Aucun séquestre de clés, aucun recouvrement, aucune gestion de clés à distance : le moyen n'ouvre aucune connexion réseau.

C. Cas d'un moyen de cryptologie relevant de la catégorie 3 de l'annexe 2 du décret n° 2007-663 du 2 mai 2007

Le déclarant déclare que le moyen relève de la catégorie 3.

Présentez le mode de commercialisation du moyen de cryptologie et le marché auquel il s'adresse

Distribution au grand public, sans négociation, sans personnalisation et sans contrat particulier. Le canal principal est l'App Store d'Apple ; d'autres canaux peuvent s'y ajouter, selon les mêmes modalités. Le marché visé est celui des porteurs d'une carte nationale d'identité finlandaise souhaitant s'authentifier auprès de services en ligne, où qu'ils résident. Le porteur résidant en France relève de l'App Store français : le moyen y est donc fourni. Le code source est public :

<https://github.com/ReFineID/ReFineID-Apple>

Expliquez pourquoi la fonctionnalité cryptographique du moyen ne peut pas être modifiée facilement par l'utilisateur

La suite cryptographique est fixée à la compilation. La suite PACE et les paramètres de domaine sont imposés par la carte et inscrits dans le produit ; aucune interface, aucun réglage et aucun fichier de configuration ne permet de choisir un algorithme, une longueur de clé ou un protocole différent. L'application est signée et son intégrité vérifiée par le système d'exploitation, qui refuse d'exécuter un binaire modifié.

Expliquez en quoi les modalités d'installation du moyen ne nécessitent pas d'assistance importante ultérieure de la part du fournisseur

L'installation se fait par l'App Store en une action. Il n'y a ni serveur à paramétrer, ni certificat à installer, ni abonnement à souscrire. Aucune intervention du fournisseur n'est requise.

D. Renouvellement d'autorisation de transfert ou d'exportation

Sans objet : première déclaration, aucune autorisation antérieure.

E. Pièces à joindre

Pièce demandée	État
Document général présentant la société	Sans objet : le déclarant est une personne physique.
Extrait K bis de moins de trois mois	Sans objet : aucune société immatriculée.
Brochure commerciale	Sans objet : le moyen est distribué sans brochure ; sa page sur l'App Store en tient lieu.
Brochure technique	Jointe : le présent dossier, rubriques B.2 et B.3.
Manuel utilisateur	Sans objet : le moyen est distribué sans manuel.
Guide administrateur	Sans objet : le moyen ne comporte aucune fonction d'administration.

F. Attestation

Je soussigné, Koistinen Petri, agissant en qualité de fournisseur et auteur du moyen et pour mon propre compte, certifie que les renseignements figurant dans le présent dossier sont exacts et ont été établis de bonne foi, et m'engage à porter à la connaissance de l'Agence

nationale de la sécurité des systèmes d'information, sans délai, tout élément nouveau de fait ou de droit de nature à modifier la présente déclaration.

Fait à Helsinki, le 4 août 2026.

Ce document est signé électroniquement. La signature est une signature électronique qualifiée : en vertu de l'article 25, paragraphe 2, du règlement (UE) n° 910/2014, elle a un effet juridique équivalent à celui d'une signature manuscrite. Validation en ligne et gratuite à l'adresse <https://dvv.fineid.fi/fr/validation>, entre autres services.

English version

Declaration of supply and of transfer from a member state of the European Union of a means of cryptology, under article 30 of law No 2004-575 of 21 June 2004 for confidence in the digital economy and chapter II of decree No 2007-663 of 2 May 2007.

ReFineID is middleware that makes the Finnish national identity card usable as a digital identity on Apple platforms. It establishes an encrypted channel with the card and so provides a confidentiality function, besides authentication, integrity and signature: its supply falls under the declaration regime.

The declarant requests the issue of the corresponding attestation de déclaration.

A. Declarant and/or applicant

The declarant is an individual. ReFineID is a trading name he uses in a personal capacity.

Field	Value
Name	Koistinen, Petri
Nationality	Finnish
Address	Niittaajankatu 8a A 21, 00810 Helsinki, Finland
Telephone	+358 44 956 4098
Email	petri.koistinen@iki.fi

Technical contact: the declarant, same details. He is also the manufacturer.

B. Means of cryptology to which the declaration and/or the authorisation request applies

B.1. General information

Field	Value
Name of the means	ReFineID
Generic designation	Middleware for a national identity card
Brand	ReFineID
Commercial reference	ReFineID for Apple platforms
Version	26.11
Date placed on the market	1 November 2026
Platforms	iOS 26, iPadOS 26, macOS 26

B.2. Functional description

B.2.1. Classification of the means

Software.

B.2.2. General description of the means

The means reads the card over the phone's NFC antenna or a contact smart-card reader, publishes the card's authentication certificate and public key to the system keychain through CryptoTokenKit, and passes signature requests to the card. Safari and other system consumers then authenticate with the card as they would with any other client certificate.

This declaration covers the Apple-platform application alone, distributed through the App Store. A ReFineID middleware for desktop systems, distributed separately and with different cryptographic functions, falls outside its scope.

B.2.3. Category of the principal function

Information security (cryptographic library and middleware).

B.3. Technical description

B.3.1. Description of the cryptographic functionality

Two functions, and nothing else:

1. **Opening a secure channel to the card.** The card refuses every read of its PKCS#15 application on the contactless interface until PACE has run. PACE derives session keys from the card access number printed on the card; every exchange afterwards is encrypted and authenticated under them.
2. **Client authentication signatures.** The private key stays in the card, which performs the signature. The means formats the input, passes it to the card, and verifies the result against the card's own public key before returning it to the operating system.

The encryption is confined to that channel and to the contactless interface alone. It is not offered to the holder: it is imposed by the card's access policy. On the contact interface the means encrypts nothing. The key published to the operating system is reserved for signature: the means offers its callers neither decryption nor key agreement.

The means does not encrypt user data at rest, does not encrypt files or storage, provides no encrypted messaging or telephony, implements no VPN or transport tunnel, and performs no network communication of its own.

B.3.2. Categories the cryptographic functions fall under

Authentication, integrity, confidentiality and signature.

B.3.3. Secure protocols used by the means

Neither IPsec, SSH, VoIP protocols, nor SSL/TLS. TLS is handled by the operating system; the means implements no TLS stack and contributes only the card's signature.

Other protocols: PACE as specified in ICAO Doc 9303 part 11 and BSI TR-03110-3; secure messaging as specified in ISO/IEC 7816-4.

B.3.4. Cryptographic algorithms used and their maximum key lengths

The brainpoolP384r1 curve operations and the CMAC are written in the means; AES, SHA-2 and ECDSA and RSA signature verification are called from the operating system's libraries. All algorithms are published by international standards bodies; none is proprietary.

Algorithm	Mode	Key size	Function
ECDH on brainpoolP384r1	PACE-GM (generic mapping)	384 bits	PACE key agreement
AES	CBC	256 bits	Confidentiality of each APDU after PACE
AES	CMAC	256 bits	Integrity of each APDU after PACE
SHA-256	n/a	n/a	Derivation of the PACE session keys
SHA-224, SHA-256, SHA-384, SHA-512	n/a	n/a	Digests of the authentication signatures
ECDSA on NIST P-384	n/a	384 bits	Signed by the card, verified locally
RSA	PKCS#1 v1.5	3072 bits	Signed by the card, verified locally
RSA	PSS	3072 bits	Signed by the card, verified locally

The digest for an ECDSA signature is chosen by the calling service; RSA card generations use SHA-256 alone.

Corresponding standards: ECDH, RFC 5639 and BSI TR-03111; AES, FIPS 197 with NIST SP 800-38A (CBC) and NIST SP 800-38B with RFC 4493 (CMAC); SHA-2, FIPS 180-4; ECDSA, FIPS 186-5 and ANSI X9.62; RSA, RFC 8017.

Key management

- The card's private keys are generated on the card by the issuing authority and never leave it. The means cannot read them and never holds them.
- PACE session keys are ephemeral: derived per session, held in memory only, released when the session ends and never written to persistent storage.
- There is no key escrow, no key recovery and no remote key management: the means opens no network connection.

C. Case of a means of cryptology falling within category 3 of annex 2 to decree No 2007-663 of 2 May 2007

The declarant declares that the means falls within category 3.

Present the means of commercialisation and the market it addresses

Distributed to the general public, with no negotiation, no customisation and no individual contract. The principal channel is the Apple App Store; other channels may be added, on the same terms. The target market is holders of a Finnish national identity card wishing to authenticate to online services, wherever they live. A holder resident in France is served by the French storefront: the means is therefore supplied in France. The source code is public:

<https://github.com/ReFineID/ReFineID-Apple>

Explain why the cryptographic functionality cannot easily be modified by the user

The cryptographic suite is fixed at compile time. The PACE suite and domain parameters are imposed by the card and written into the product; no interface, setting or configuration file allows a different algorithm, key length or protocol to be chosen. The application is signed and its integrity verified by the operating system, which refuses to run a modified binary.

Explain how installation requires no significant subsequent support from the supplier

Installation is a single action through the App Store. There is no server to configure, no certificate to install and no service to subscribe to. No supplier intervention is required.

D. Renewal of a transfer or export authorisation

Not applicable: a first declaration, with no prior authorisation.

E. Documents to attach

Item requested	Status
General document presenting the company	Not applicable: the declarant is a private individual.
Extract K bis less than three months old	Not applicable: no registered company.
Commercial brochure	Not applicable: the means is distributed without one; its public listing serves instead.
Technical brochure	Attached: this dossier, sections B.2 and B.3.
User manual	Not applicable: the means is distributed without one.
Administrator guide	Not applicable: the means has no administration function.

F. Attestation

I, the undersigned, Koistinen Petri, acting as supplier and author of the means and on my own behalf, certify that the information in this dossier is accurate and has been established in good faith, and undertake to inform the Agence nationale de la sécurité des systèmes d'information without delay of any new matter of fact or of law liable to alter this declaration.

Done at Helsinki, 4 August 2026.

This document is electronically signed. The signature is a qualified electronic signature: under Article 25(2) of Regulation (EU) No 910/2014 it has legal effect equivalent to that of a handwritten signature. Validation is available online, free of charge, at <https://dvv.fineid.fi/en/validation>, among other services.